

SOC Interview Questions & Answers Guide

1. What is the role of a SOC Analyst?

Answer:

A SOC Analyst is responsible for monitoring, detecting, analyzing, and responding to cybersecurity incidents. They use SIEM & Network Security and Traffic Analysis tools, analyze security alerts, investigate threats, and coordinate incident response efforts to protect an organization's IT Infrastructure.

2. What are the different SOC tiers, and how do they function?

Answer:

- **Tier 1 (L1) - Security Monitoring:** Monitors alerts, performs initial triage, and escalates incidents.
 - **Tier 2 (L2) - Incident Response:** Investigate escalated alerts, perform deep analysis and mitigate threats.
 - **Tier 3 (L3) - THreat Hunting & Forensics:** Proactively searches for advanced threats, analyzes malware, and provides strategic improvements.
 - **SOC Manager:** Oversees operations, coordinates between teams, and ensures security policies are enforced.
-

3. What are SIEM Tools, and Why are they Important?

Answer:

SIEM (Security Information and Event Management) tools collect, analyze and correlate logs from various sources to detect security threats. Examples include: Splunk, IBM, QRadar, Azure Sentinel, and ArcSight. They help identifying anomalies, automating alerts, and supporting compliance.

4. What is the difference between IDS and IPS?

Answer:

- **Intrusion Detection System (IDS):** Monitors Network Traffic for malicious activity and generates alerts.

- **Intrusion Prevention System (IPS):** Acts as an active security measure by blocking detection threats in real time.
-

5. What is Nmap and how does it work?

Answer:

Nmap (Network Mapper) is a tool to scan networks and discover hosts, services, and open ports. It works by sending specially crafted packets to the target and analyzing the responses.

6. How do you analyze packets for suspicious activity?

Answer:

In Wireshark, apply display filters like ``http``, ``tcp.port == 22``, or ``dns`` to isolate traffic. Look for anomalies like repeated failed login attempts or unusual destinations.

7. How do you respond to a phishing attack?

Answer:

- Analyse the emails headers and links using tools like VirusTotal, URLScan, and IPVoid.
 - Check sender reputation and email anomalies.
 - Quarantine if any user clicked the link or downloaded malicious files.
 - Educate users on phishing awareness and update email security policies.
-

8. What are the steps in the Incident Response (IR) process?

Answer:

1. **Identification:** Detects and validates security incidents.
 2. **Containment:** Isolate affected systems to prevent further damage.
 3. **Eradication:** Remove threats and malicious files.
 4. **Recovery:** Restore affected systems and resume operations.
 5. **Lessons Learned:** Conduct post-incident analysis to improve defences.
-

9. How do you differentiate between a False Positive and False Negative?

Answer:

- **False Positive:** A benign event incorrectly flagged as a threat (e.g. a legitimate login marked as a brute force.)
 - **False Negative:** A real threat that goes undetected (e.g.: malware bypassing detection systems).
 - SOC analysts fine-tune security rules and thresholds to minimize false positives/negatives.
-

10. What is MITRE ATT&CK Framework?

Answer:

MITRE ATT&CK is a Knowledge base of adversary tactics, techniques, and procedures (TTPs) used for threat hunting, red teaming, and security assessment. It categorizes cyber threats into Initial Access, Execution, Persistence, Privilege Escalation, etc.

11. What are some common log sources in a SOC?

Answer:

- **Network Logs:** Firewall, IDS/IPS, VPN logs
 - **Endpoint Logs:** EDR solutions (e.g.: Microsoft Defender, CrowdStrike)
 - **Application Logs:** Web servers, databases
 - **Cloud Logs:** AWS cloudTrail, Azure Security Center
 - **Authentication Logs:** Active Directory, Okta, Radius
-

12. What is a Brute Force Attack? How can you prevent it?

Answer:

A brute force attack is when an attacker repeatedly tries different username-password combinations to gain access.

Mitigation:

- Implement Account Lockout Policies
- Enforce Multi-Factor Authentication (MFA)
- Use CAPTCHA and rate limiting
- Monitor for multiple failed login attempts.

13. What are Indicators Of Compromise (IoCs)?

Answer:

IoCs are evidence of a security breach, such as:

- IP addresses of known attackers
 - Malicious file hashes (MD5, SHA256)
 - Suspicious domain names and URLs
 - Unusual Login activities.
-

14. What is a DDoS attack, and how can it be mitigated?

Answer:

A Distributed Denial-of-Service (DDoS) attack overwhelms a server or network with excessive traffic.

Mitigation:

- Use Rate Limiting and WAF (Web Application Firewall)
 - Deploy CDN (Content Delivery Network) to absorb traffic
 - Implement Geo-blocking for suspicious locations.
-

15. Difference Between Vulnerability Scanning and Penetration Testing?

Answer:

- **Vulnerability Scanning:** Identifies security weaknesses in a system using tools like Nessus, Quals, and Rapid7.
 - **Penetration Testing:** Actively exploits vulnerabilities to access the system's security.
-

16. Explain Splunk architecture (Forwarder, Indexer, Search Head)

Answer:

Splunk uses Forwarders to collect data, Indexers to store and process it, and Search Head to query and visualize data via dashboards.

17. What is an index and sourcetype?

Answer: An index is a storage location for logs in Splunk, and a sourcetype is a classification for the log format (e.g.: syslog, json, access_combined).

18. How do you use Burp to detect SQLi or XSS?

Answer:

Use the repeater to manually test inputs and scanner to automatically find vulnerabilities SQLi shows database errors; XSS reflects injected scripts in responses.

19. What is Hydra Used for?

Answer:

Hydra is a brute-force tool used to crack login credentials for services like SSH, FTP, HTTP, etc. by trying multiple username-password combinations.

20. (**IMPORTANT**) What tools have you used for security analysis and investigations?

Answer:

- **SIEM tools:** Splunk, QRadar, Azure Sentinel
 - **Endpoint Security:** Microsoft defender 365, CrowdStrike, SentinelOne
 - **Threat Intelligence:** VirusTotal, Shodan.io, Cyberchat
 - **Firewall & Network Security:** Palo Alto, FortiGate, F5 WAF
-

21. Port numbers for SSH, SMB, DNS, RDP?

Answer:

SSH: 22, SMB: 445, DNS: 53, RDP: 3389

22. How does a SOC use ATT&CK?

Answer:

SOC analyst map alerts to ATT&CK techniques to understand attacker behavior, improve detection rules, and prioritize responses.

MITRE ATT&CK: Top 10 Tactics & Techniques with T-Numbers

1. Initial Access

- Phishing Email Attachment (T1566.001)
- Exploit Public-Facing Application (T1190)

2. Execution

- PowerShell Execution (T1059.001)
- Command and Scripting Interpreter (T1059)

3. Persistence

- Registry Run Keys / Startup Folder (T1547.001)
- Create Account (T1136)

4. Privilege Escalation

- Bypass User Account Control (T1548.002)
- Exploitation for Privilege Escalation (T1068)

5. Defense Evasion

- Obfuscated Files or Information (T1027)
- Indicator Removal on Host (T1070.004)

6. Credential Access

- Credential Dumping (T1003)
- Brute Force (T1110)

7. Discovery

- Network Service Scanning (T1046)
- System Information Discovery (T1082)

8. Lateral Movement

- Remote Services: SMB/RDP (T1021.002)
- Pass-the-Hash (T1550.002)

9. Collection

- Screen Capture (T1113)
- Clipboard Collection (T1115)

10. Exfiltration

- Exfiltration Over Web Service (T1567)
- Exfiltration via Email (T1048)